

Paper Writeup(s) to be Submitted before 15 Jan

Aaryan Bhagat

Student ID: 862468325

IP Spoofing Demystified

This paper's objective is straightforward, it wants to explain how can one machine (A) imitate another's machine's IP (B) when interacting with a third machine (C). This is done when a malicious machine A wants to exploit C and in order to do that, it will try to establish a trustful (exact context of "trustful" here is the elevated privileges of communication between B and C) relationship by imitating the IP of machine B, a device which C already trusts.

Working: The attack machine disables the trustable machine using SYN Flooding mechanism. Meanwhile the attacker gets a reliable idea of the target's ISN number and the RTT by making a connection to it. Now the attacker spooks the IP address to be of the trusted host's IP address and sends an ACK response to the target with the predicted accurate sequence number + 1. If the prediction is correct the target machine C will think A to be the trusted source B.

Pros: The paper language is very fluent, the authors clearly know their target audience (geeky kids!) and instead of adding verbiage they have kept the content simple + light humour, side by side not downgrading the complexity of the topic, a commendable feat overall. Moreover, for understanding the attack, its motivation and its mitigations is very easy and only need little prerequisites.

Assumption: Background Information of the target machine is required, we need to find the IP of at least a single trusted machine (B in our case) which is trusted by C. Non random sequence number generation.

Problems/Cons: Multitude of problems in this attack is described by the paper itself. If there is no trusted host in the list of trusted hosts in the target device, the attack will never work. Also, one of the underlying vulnerability for this attack to work is dependent upon softwares like rclient (as shown in the paper) who bypass authentication if request is coming from a known IP. Using other, more safe, wrappers over TCP like ssh will make this attack void. Randomised sequence numbers can make prediction much more tough.

The biggest drawback of the paper, something over which they had no control, is the time, its publication is 1996. Since that, we have come a long way to tackle IP spoofing and other attack vectors, secure cryptographic protocols of today like TLS mitigate spoofing, or even multi factor authentication for example, where even if you are from a trusted source, the target host sends a confirmation to another device and then proceeds to form a complete connection.

Even to turn the trustable machine B off using SYN Flooding is mitigated in modern time by various Load Balancers in the network path or if the trustable machine B has his own firewall which will blacklist an IP sending a flood of SYN packets.

The current value of this paper according to me is beneficial to be taught in a course for students to grasp the fundamental of how certain network protocols work and how can they be exploited.

Blind TCP/IP hijacking is still alive

The paper presents a method of Blind TCP Hijacking which works on various different OS distributions. Its fundamentally a session hijacking, here session implies a TCP session, (between 2 devices, a client and a server) attack presented in 2007 with the main focus of the paper being

that an old attack vector (prominent in late 90s and early 2000s) is still applicable today on a wide range of targets online.

Working: The main motivation of the paper is the exploitation of the underlying implementation (in client's OS) which assigns IP_ID flag, its a 16-bit number unique for each IP packet. Since some network stacks of various kernels keep a global counter of the IP ID, one can probe it using various requests (most commonly the ICMP packet request i.e a ping)

Pros: Paper understanding requires less pre-requisites as most of them are contained in the paper itself. The concepts are explained with extensive corresponding small examples. The attack is applicable (and tested by the authors) on a wide range of OS distributions (here it implies the Client's OS, server side OS can be anything, its immaterial).

Assumptions: Attack is dependent upon non randomised IP IDs, why such an implementation exists in the first place is a valid question and I think they were just naive implementations (maybe the developers did not think of this attack vector?) because as the paper itself explains, there certainly exists non trivial implementations to assign random IP IDs in various kernels.

Problems/Cons: Most limitations are described in the paper itself. This attack cannot work if an OS kernel stack implements a non trivial scheme to assign IP IDs. If the client is behind a strong firewall then many type of probes by the attacker (even ping probes) will be blocked and this will nullify the attack completely. Another limitation discussed is the need for a stable and peaceful internet connection for the client because an unstable or a high traffic connection can cause a flood of IP ID messages and disrupt the analysis of the attacker to predict the correct sequence number.

What I do not like is the ultimate cat and mouse game which ensues, one has to find the client's SND.NEXT and the server's SND.NEXT for complete session hijacking, although the authors have given clever methods of binary search and giving worst case analysis, this approach still depends upon the latency between client and server (because it determines the time after which client will send RST connection to abort the connection). The authors do not elaborate more on this and leave it as an exercise to the reader to create an efficient client-port scanner.

One thing which really stood out to me was that even if the attack fails, the method still can be used to perform recon of various client-server groups as the initial steps of the method finds client and server ports which are communicating with each other.